보안 · 개인정보 점검

ID	구분	내용
NFR-01	보안	이 PC에서만 열림(127.0.0.1), Host·Origin 검사
NFR-02	보안	비밀번호는 PBKDF2-SHA256(24만 회)+솔트 해시로만 저장, 원문 저장·로그 없음
NFR-03	보안	세션 쿠키 HttpOnly·SameSite=Strict, 8시간 만료, 서버를 끄면 모두 로그아웃, 5회 실패 시 60초 잠금
NFR-04	개인정보	호출 내용·이벤트·계정은 data/ 폴더에만 저장하고 깃에 올리지 않음
NFR-05	개인정보	API 키는 저장·출력하지 않음(환경 변수에서 읽어 헤더로만 전송)
NFR-06	유지보수	외부 파이썬 라이브러리 없이 표준 라이브러리만 사용
NFR-08	보안	AI 키·토큰은 앱에서 입력한 것만 쓰고 윈도우 사용자 계정으로 암호화(DPAPI)해 data/에 저장. 화면·API 응답·로그에 키 값이 나오지 않음
NFR-09	개인정보	환경 변수 키·이 PC의 기존 Codex 로그인은 기본 꺼짐(사용자가 연동 창에서 켜야 사용)
NFR-07	신뢰성	실패·한도 상황을 숨기지 않고 사유와 함께 표시

AI 토큰(연동) 보호

- 연결하지 않으면 호출 자체가 되지 않음(외부 호출 없음)
- 키는 암호화 저장, 응답·화면에 없음
- 이 PC의 기존 로그인·환경 변수는 기본 꺼짐

깃 업로드 전 점검

- data/, 바로가기(.lnk), 실행 기록은 .gitignore 로 제외
- tools/check_privacy.py 로 개인 경로·이메일·키·기록 파일 검사
- 스크린샷은 데모 모드(가짜 데이터)로만 촬영
- 업로드용 깨끗한 사본(release/)은 개발 중 기록 없이 새로 만든다